DBA BRABO

Avaliacao de Seguranca do Banco de Dados MySQL

Relatorio tecnico de assessment — gerado pelo MyBraboSat

SERVIDOR	VERSAO DO MYSQL	DATA DA COLETA	NOTA DE POSTURA
vm	**8.0.46-0ubuntu0.24.04.4**	**22/10/2026 15:58**	**66/100**

Coleta executada por **root@localhost**. Este documento retrata a configuracao do servidor no instante da coleta.
Ferramenta: MyBraboSat 1.0.0 — by • DBA BRABO.

ALTAMENTE CONFIDENCIAL — DISTRIBUICAO RESTRITA

INDICE

1. Sobre este documento — escopo e metodo
2. Como ler o relatorio — severidades e estados
3. Seguranca em MySQL — por que isto importa
4. Sumario executivo — nota 66/100
5. Falhas e remediacao — 9 item(ns)
6. Itens para avaliar — 20 item(ns)
7. Todas as verificacoes — 53 checks
8. Inventario do servidor — contexto tecnico
9. Limitacoes e proximos passos
10. Referencias

1. Sobre este documento

Este relatorio e o resultado de uma coleta automatizada de configuracao em um servidor MySQL. Ele nao substitui um teste de intrusao nem uma revisao de codigo da aplicacao: olha para como o banco esta configurado, quem tem acesso a ele e o que o servidor registra sobre esse acesso.

O que a ferramenta faz

O MyBraboSat executa 53 verificacoes somente de leitura contra `mysql`, `information_schema` e `performance_schema`. Nenhuma alteracao e feita no servidor: o script cria apenas uma tabela temporaria de sessao, que desaparece ao desconectar. A coleta dura segundos e pode ser repetida a qualquer momento para acompanhar a evolucao.

Metodo

Cada verificacao recebe uma severidade e um estado. A severidade reflete o impacto caso o item seja explorado; o estado reflete o que foi encontrado. Itens que dependem do contexto da aplicacao nao sao tratados como falha: vao para uma secao propria, de avaliacao. A nota de postura pondera as falhas pela severidade, de modo que uma unica falha critica pesa mais do que varias de baixa.

Escopo

Servidor **vm**, MySQL 8.0.46-0ubuntu0.24.04.4, coletado em 22/10/2026 as 15:58 pela conta `root@localhost`. Estao fora do escopo: seguranca do sistema operacional, regras de firewall, backup e sua testagem de restauracao, seguranca da aplicacao que consome o banco, e replicas ou nos de cluster nao incluidos nesta coleta.

2. Como ler o relatorio

As tabelas deste documento usam duas classificacoes. Conhece-las evita a leitura errada mais comum, que e tratar todo apontamento como defeito.

Severidade — qual o impacto se o item for explorado

SEVERIDADE	PESO	SIGNIFICADO
CRITICA	10	Permite acesso nao autorizado ao dado ou ao servidor, de forma direta e sem obstaculo. Corrigir antes de qualquer outra coisa.
ALTA	6	Amplia bastante a superficie de ataque ou elimina uma barreira importante. Entra no proximo ciclo de mudanca.
MEDIA	3	Boa pratica consolidada que nao esta aplicada. Enfraquece defesa em profundidade ou rastreabilidade.
BAIXA	1	Endurecimento incremental. Vale aplicar quando houver janela.
INFO	0	Inventario e contexto. Nao entra na nota.

Estado — o que foi encontrado

ESTADO	SIGNIFICADO
PASS	A configuracao esta de acordo com a recomendacao.
FAIL	A recomendacao nao esta aplicada. Perde o peso inteiro na nota.
AVALIAR	Depende do contexto: pode ser aceitavel, pode ser risco. Perde metade do peso. Exige decisao humana, nao correcao automatica.
NA	Nao aplicavel a esta versao ou edicao do MySQL.

Nota de postura = 100 x (1 − peso perdido / peso total). Nesta coleta: 66/100.

3. Seguranca em MySQL: por que isto importa

O banco de dados e o ultimo lugar onde o dado existe em forma utilizavel. Firewall, WAF e autenticacao da aplicacao sao camadas que protegem o caminho ate ele; quando qualquer uma falha, o que resta e a configuracao do proprio servidor. E ela que decide se o invasor encontra uma copia legivel de tudo ou uma barreira a mais.

Na pratica, os incidentes com MySQL raramente comecam com uma falha exotica do produto. Comecam com o feijao com arroz: conta sem senha que sobrou de uma migracao, conta de aplicacao com privilegio global porque era mais rapido do que calcular o minimo necessario, trafego de replicacao em texto claro entre dois datacenters, binlog sem criptografia num volume que foi descartado sem apagar, ausencia de auditoria que impede saber o que foi acessado depois que o incidente ja aconteceu.

Os quatro eixos avaliados

Identidade e privilegio. Quem entra e o que pode fazer. O principio e o do menor privilegio: cada conta recebe exatamente o que precisa, nem mais. Privilegios amplos como `FILE` e `SUPER` transformam qualquer comprometimento de aplicacao em comprometimento do servidor.

Criptografia. Em transito e em repouso. TLS protege o dado entre aplicacao e banco, e entre no primario e replicas. A criptografia de tablespace, redo, undo e binlog protege o dado quando o meio fisico sai do seu controle, por descarte, roubo ou snapshot de nuvem.

Superficie de ataque. Todo recurso ligado e um recurso que pode ser abusado. `local_infile`, `secure_file_priv` vazio, protocolo X ativo sem uso e schemas de teste esquecidos sao portas que ninguem precisa manter abertas.

Rastreabilidade. Auditoria nao impede o incidente; ela responde o que aconteceu. Sem trilha de acesso, a pergunta que a diretoria e o regulador fazem depois do vazamento — quais dados foram acessados, por quem e quando — nao tem resposta.

O recorte regulatorio

A LGPD nao prescreve tecnologia, mas o artigo 46 exige medidas tecnicas aptas a proteger o dado pessoal. Criptografia, controle de acesso e trilha de auditoria sao justamente as evidencias que se apresenta para demonstrar essa aptidao. O CIS Benchmark para MySQL cumpre o papel de baseline reconhecida: e por isso que as verificacoes deste relatorio trazem a referencia CIS correspondente, quando existe.

4. Sumario executivo

Retrato da postura em uma tela. A nota pondera as falhas pela severidade; os cartoes mostram a distribuicao. Use esta secao para decidir prioridade, e as duas seguintes para executar.

66

NOTA DE POSTURA (0–100)

Varias frentes abertas. Priorize as de severidade alta.

0	7	2	0	20	24
CRITICAS	ALTAS	MEDIAS	BAIXAS	A AVALIAR	CONFORMES

53

VERIFICACOES

5. Falhas e remediacao

Itens em que a recomendacao nao esta aplicada, ordenados por severidade. Cada linha traz o que foi encontrado no servidor, o comando de correcao e o link para a documentacao oficial. Os comandos usam `SET PERSIST` onde o parametro aceita, o que sobrevive a reinicializacao sem editar arquivo; onde exige `my.cnf`, isso esta dito na propria linha.

Antes de aplicar: valide em ambiente de homologacao. Parametros como `require_secure_transport` e `local_infile` derrubam conexao de aplicacao que dependa do comportamento antigo.

SEV	VERIFICACAO	O QUE FOI ENCONTRADO	COMO CORRIGIR	DOC
ALTA	**Administrador acessivel de qualquer host** Contas e autenticacao	1 conta(s) administrativa(s) com host '%': sh@%	`RENAME USER '<user>'@'%' TO '<user>'@'<ip ou rede especifica>';`	CIS 1.5
ALTA	**Componente validate_password ativo** Contas e autenticacao	Nenhuma validacao de forca de senha no servidor.	`INSTALL COMPONENT 'file://component_validate_password';`	CIS 1.1
ALTA	**Privilegio FILE concedido** Privilegios	FILE concedido a: 'debian-sys-maint'@'localhost', 'root'@'localhost', 'sh'@'%' — permite ler e escrever arquivos no servidor.	`REVOKE FILE ON *.* FROM '<user>'@'<host>';`	CIS 2.1
ALTA	**require_secure_transport** Rede e criptografia	require_secure_transport = OFF — conexao sem TLS continua sendo aceita.	`SET PERSIST require_secure_transport = ON;`	CIS 6.x
ALTA	**Criptografia em repouso (tablespace)** Rede e criptografia	Nenhuma tabela cifrada em repouso.	`ALTER TABLE <schema>.<tabela> ENCRYPTION='Y'; -- exige componente de keyring carregado`	CIS 7.x
ALTA	**Componente de keyring ativo** Rede e criptografia	Nenhum keyring. Sem ele nao ha criptografia de tablespace, redo nem binlog.	`Configure component_keyring_file (ou o keyring corporativo) em mysqld.my e carregue com INSTALL COMPONENT.`	CIS 7.x
ALTA	**Auditoria instalada** Log e auditoria	Nenhum plugin de auditoria. Sem isso nao ha trilha de quem acessou o que.	`Enterprise: INSTALL COMPONENT 'file://component_audit_log'. Community: use audit_log do Percona Server ou server_audit do MariaDB/Percona.`	CIS 5.x
MEDIA	**Historico de senhas (anti-reuso)** Contas e autenticacao	password_history = 0 (0 = permite repetir a senha anterior)	`SET PERSIST password_history = 6; SET PERSIST password_reuse_interval = 365;`	CIS 1.7
MEDIA	**Bloqueio por tentativas malsucedidas** Contas e autenticacao	Nenhuma conta com bloqueio automatico apos erros de senha.	`ALTER USER '<user>'@'<host>' FAILED_LOGIN_ATTEMPTS 5 PASSWORD_LOCK_TIME 1;`	Boa pratica

6. Itens para avaliar

Nao sao defeitos. Sao decisoes que dependem do desenho da aplicacao e do apetite a risco da empresa — por exemplo, exigir certificado de cliente em toda conta, ou cifrar o binlog num ambiente onde o volume ja e cifrado pelo storage. Cada item traz a sugestao tecnica; a escolha e de quem conhece o contexto.

Nao sao falhas: dependem do contexto da sua aplicacao e do apetite a risco da empresa.

SEV	VERIFICACAO	SITUACAO	SUGESTAO	DOC
ALTA	**Contas com privilegio global perigoso** Privilegios	18 conta(s) com SUPER/FILE/PROCESS/SHUTDOWN/GRANT global: 'debian-sys-maint'@'localhost' [CREATE USER]; 'debian-sys-maint'@'localhost' [FILE]; 'debian-sys-maint'@'localhost' [PROCESS]; 'debian-sys-maint'@'localhost' [RELOAD]; 'debian-sys-maint'@'localhost' [SHUTDOWN]; 'debian-sys-maint'@'localhost' [SUPER]; 'root'@'localhost' [CREATE USER]; 'root'@'localhost' [FILE]; 'root'@'localhost' [PROCESS]; 'root'@'localhost' [RELOAD]; 'root'@'localhost' [SHUTDOWN]; 'root'@'localhost' [SUPER]; 'sh'@'%' [CREATE USER]; 'sh'@'%' [FILE]; 'sh'@'%' [PROCESS]; 'sh'@'%' [RELOAD]; 'sh'@'%' [SHUTDOWN]; 'sh'@'%' [SUPER]	`REVOKE <privilegio> ON *.* FROM '<user>'@'<host>'; prefira privilegios dinamicos especificos (ex.: BINLOG_ADMIN, SYSTEM_VARIABLES_ADMIN).`	CIS 2.x
MEDIA	**authentication_policy** Contas e autenticacao	authentication_policy = *,,	`SET PERSIST authentication_policy = '*,,'; -- primeiro fator obrigatorio = default_authentication_plugin forte`	MySQL 8.4
MEDIA	**Expiracao de senha no servidor** Contas e autenticacao	default_password_lifetime = 0 (0 = senha nunca expira)	`SET PERSIST default_password_lifetime = 180;`	CIS 1.6
MEDIA	**Separacao por roles** Contas e autenticacao	Nenhuma role definida — privilegios provavelmente concedidos direto nas contas.	`CREATE ROLE 'app_leitura'; GRANT SELECT ON app.* TO 'app_leitura'; GRANT 'app_leitura' TO 'conta'@'host';`	CIS 1.x
MEDIA	**Rotinas com SQL SECURITY DEFINER** Privilegios	1 rotina(s) executam com o privilegio do criador, nao do chamador.	`ALTER PROCEDURE <nome> SQL SECURITY INVOKER; -- quando o chamador ja tiver o privilegio necessario`	CIS 2.x
MEDIA	**Contas sem exigencia de SSL** Rede e criptografia	4 conta(s) sem REQUIRE SSL/X509 — dependem so do require_secure_transport global.	`ALTER USER '<user>'@'<host>' REQUIRE SSL; -- ou REQUIRE X509 para exigir certificado de cliente`	CIS 6.x
MEDIA	**Redo log cifrado** Rede e criptografia	innodb_redo_log_encrypt = OFF	`SET PERSIST innodb_redo_log_encrypt = ON;`	CIS 7.x
MEDIA	**Undo log cifrado** Rede e criptografia	innodb_undo_log_encrypt = OFF	`SET PERSIST innodb_undo_log_encrypt = ON;`	CIS 7.x
MEDIA	**Binary log cifrado** Rede e criptografia	binlog_encryption = OFF — o binlog carrega os dados alterados em claro quando desligado.	`SET PERSIST binlog_encryption = ON;`	CIS 7.x
MEDIA	**Colunas candidatas a dado pessoal** Dados sensiveis	12 coluna(s) com nome sugestivo de dado pessoal. Classifique e decida mascaramento, cifra ou minimizacao.	`Classifique os dados; avalie cifra em coluna, mascaramento na view ou component_masking.`	LGPD art. 46
BAIXA	**Conta root com nome padrao** Contas e autenticacao	A conta administrativa ainda se chama root — alvo obvio de forca bruta.	`RENAME USER 'root'@'localhost' TO '<nome nao obvio>'@'localhost';`	Boa pratica
BAIXA	**Exigir senha atual para troca** Contas e autenticacao	password_require_current = OFF	`SET PERSIST password_require_current = ON;`	Boa pratica
BAIXA	**partial_revokes habilitado** Privilegios	partial_revokes = OFF — com ON da para conceder *.* e revogar schemas sensiveis especificos.	`SET PERSIST partial_revokes = ON;`	Boa pratica

BAIXA	**Views com SQL SECURITY DEFINER** Privilegios	1 view(s) com DEFINER fora dos schemas do sistema.	`ALTER VIEW <nome> SQL SECURITY INVOKER AS ...;`	Boa pratica
BAIXA	**skip_name_resolve** Configuracao segura	skip_name_resolve = OFF — com OFF o controle de acesso depende de DNS, que pode ser envenenado.	`Adicione skip-name-resolve no my.cnf e troque hosts por IP/rede nas contas.`	CIS 4.x
BAIXA	**Plugin X Protocol (mysqlx)** Configuracao segura	X Protocol ativo na porta 33060 — desligue se a aplicacao nao usa Document Store.	`Adicione mysqlx=0 no my.cnf, ou UNINSTALL PLUGIN mysqlx;`	Superficie de ataque
BAIXA	**Banner de versao exposto** Configuracao segura	version = 8.0.46-0ubuntu0.24.04.4 / version_comment = (Ubuntu) — a versao exata aparece no handshake, antes de qualquer autenticacao.	`SET PERSIST version_comment = ''; -- nao esconde a versao, mas reduz a informacao oferecida`	Boa pratica
BAIXA	**automatic_sp_privileges** Configuracao segura	automatic_sp_privileges = ON — com ON quem cria rotina ganha EXECUTE e ALTER ROUTINE automaticamente.	`SET PERSIST automatic_sp_privileges = OFF;`	CIS 4.x
BAIXA	**Slow query log ativo** Log e auditoria	slow_query_log = OFF	`SET PERSIST slow_query_log = ON;` `SET PERSIST long_query_time = 1;`	Operacao
BAIXA	**Tabelas sem chave primaria** Dados sensiveis	1 tabela(s) sem PK — atrapalham replicacao por linha, PITR e rastreio de alteracao.	`ALTER TABLE <schema>.<tabela> ADD PRIMARY KEY (<coluna>);`	Rastreabilidade

7. Todas as verificacoes

A lista completa, inclusive o que passou. Serve como evidencia de cobertura em auditoria: mostra nao apenas o que falhou, mas tudo o que foi examinado.

DOMINIO	VERIFICACAO	SEV	ESTADO	DETALHE
Contas e autenticacao	Conta sem senha definida	CRITICA	**PASS**	Nenhuma conta sem senha.
Contas e autenticacao	Conta anonima	CRITICA	**PASS**	Nenhuma conta anonima.
Contas e autenticacao	Administrador acessivel de qualquer host	ALTA	**FAIL**	1 conta(s) administrativa(s) com host '%': sh@%
Contas e autenticacao	root acessivel remotamente	ALTA	**PASS**	root so acessa localmente.
Contas e autenticacao	Conta root com nome padrao	BAIXA	**AVALIAR**	A conta administrativa ainda se chama root — alvo obvio de forca bruta.
Contas e autenticacao	Autenticacao com mysql_native_password	ALTA	**PASS**	Nenhuma conta usa mysql_native_password.
Contas e autenticacao	authentication_policy	MEDIA	**AVALIAR**	authentication_policy = *,,
Contas e autenticacao	Componente validate_password ativo	ALTA	**FAIL**	Nenhuma validacao de forca de senha no servidor.
Contas e autenticacao	Expiracao de senha no servidor	MEDIA	**AVALIAR**	default_password_lifetime = 0 (0 = senha nunca expira)
Contas e autenticacao	Historico de senhas (anti-reuso)	MEDIA	**FAIL**	password_history = 0 (0 = permite repetir a senha anterior)
Contas e autenticacao	Exigir senha atual para troca	BAIXA	**AVALIAR**	password_require_current = OFF
Contas e autenticacao	Bloqueio por tentativas malsucedidas	MEDIA	**FAIL**	Nenhuma conta com bloqueio automatico apos erros de senha.
Contas e autenticacao	Contas de sistema devidamente travadas	INFO	**PASS**	3 conta(s) com account_locked = Y (esperado para mysql.sys, mysql.session, mysql.infoschema).
Contas e autenticacao	Separacao por roles	MEDIA	**AVALIAR**	Nenhuma role definida — privilegios provavelmente concedidos direto nas contas.
Contas e autenticacao	activate_all_roles_on_login	BAIXA	**PASS**	activate_all_roles_on_login = OFF
Privilegios	Contas com privilegio global perigoso	ALTA	**AVALIAR**	18 conta(s) com SUPER/FILE/PROCESS/SHUTDOWN/GRANT global: 'debian-sys-maint'@'localhost' [CREATE US 'debian-sys-maint'@'localhost' [PROCESS]; 'debian-sys-maint'@'localhost' [RELOAD]; 'debian-sys-maint'@'localhos [SUPER]; 'root'@'localhost' [CREATE USER]; 'root'@'localhost' [FILE]; 'root'@'localhost' [PROCESS]; 'root'@'localh 'root'@'localhost' [SUPER]; 'sh'@'%' [CREATE USER]; 'sh'@'%' [FILE]; 'sh'@'%' [PROCESS]; 'sh'@'%' [RELOAD]; '
Privilegios	Privilegio FILE concedido	ALTA	**FAIL**	FILE concedido a: 'debian-sys-maint'@'localhost', 'root'@'localhost', 'sh'@'%' — permite ler e escrever arquivos no s
Privilegios	GRANT OPTION fora da administracao	ALTA	**PASS**	Nenhuma conta comum pode repassar privilegio.
Privilegios	Escrita nos schemas do sistema	CRITICA	**PASS**	Nenhuma conta comum escreve em mysql/sys.
Privilegios	partial_revokes habilitado	BAIXA	**AVALIAR**	partial_revokes = OFF — com ON da para conceder *.* e revogar schemas sensiveis especificos.
Privilegios	Rotinas com SQL SECURITY DEFINER	MEDIA	**AVALIAR**	1 rotina(s) executam com o privilegio do criador, nao do chamador.
Privilegios	Views com SQL SECURITY DEFINER	BAIXA	**AVALIAR**	1 view(s) com DEFINER fora dos schemas do sistema.
Privilegios	DEFINER apontando para conta inexistente	MEDIA	**PASS**	Todo DEFINER aponta para uma conta que existe.

Rede e criptografia	TLS configurado no servidor	CRITICA	**PASS**	Certificado em uso: server-cert.pem
Rede e criptografia	require_secure_transport	ALTA	**FAIL**	require_secure_transport = OFF — conexao sem TLS continua sendo aceita.
Rede e criptografia	Versoes de TLS aceitas	ALTA	**PASS**	tls_version = TLSv1.2,TLSv1.3
Rede e criptografia	Contas sem exigencia de SSL	MEDIA	**AVALIAR**	4 conta(s) sem REQUIRE SSL/X509 — dependem so do require_secure_transport global.
Rede e criptografia	Criptografia em repouso (tablespace)	ALTA	**FAIL**	Nenhuma tabela cifrada em repouso.
Rede e criptografia	Componente de keyring ativo	ALTA	**FAIL**	Nenhum keyring. Sem ele nao ha criptografia de tablespace, redo nem binlog.
Rede e criptografia	Redo log cifrado	MEDIA	**AVALIAR**	innodb_redo_log_encrypt = OFF
Rede e criptografia	Undo log cifrado	MEDIA	**AVALIAR**	innodb_undo_log_encrypt = OFF
Rede e criptografia	Binary log cifrado	MEDIA	**AVALIAR**	binlog_encryption = OFF — o binlog carrega os dados alterados em claro quando desligado.
Configuracao segura	local_infile desligado	ALTA	**PASS**	local_infile = OFF
Configuracao segura	secure_file_priv restrito	ALTA	**PASS**	secure_file_priv = '/var/lib/mysql-files/'
Configuracao segura	Symbolic links desabilitados	MEDIA	**PASS**	have_symlink = DISABLED
Configuracao segura	skip_name_resolve	BAIXA	**AVALIAR**	skip_name_resolve = OFF — com OFF o controle de acesso depende de DNS, que pode ser envenenado.
Configuracao segura	Plugin X Protocol (mysqlx)	BAIXA	**AVALIAR**	X Protocol ativo na porta 33060 — desligue se a aplicacao nao usa Document Store.
Configuracao segura	Banner de versao exposto	BAIXA	**AVALIAR**	version = 8.0.46-0ubuntu0.24.04.4 / version_comment = (Ubuntu) — a versao exata aparece no handshake, antes d
Configuracao segura	sql_mode com STRICT	MEDIA	**PASS**	sql_mode = ONLY_FULL_GROUP_BY,STRICT_TRANS_TABLES,NO_ZERO_IN_DATE,NO_ZERO_DATE,ERROR_FOR_DIVI
Configuracao segura	automatic_sp_privileges	BAIXA	**AVALIAR**	automatic_sp_privileges = ON — com ON quem cria rotina ganha EXECUTE e ALTER ROUTINE automaticamente
Configuracao segura	Schema de teste presente	MEDIA	**PASS**	Nenhum schema de teste.
Configuracao segura	Tabelas fora do InnoDB	MEDIA	**PASS**	Todas as tabelas de aplicacao usam InnoDB.
Log e auditoria	Error log em arquivo	MEDIA	**PASS**	log_error = /var/log/mysql/error.log
Log e auditoria	Verbosidade do error log	BAIXA	**PASS**	log_error_verbosity = 2 (1=erro, 2=erro+warning, 3=+nota)
Log e auditoria	Auditoria instalada	ALTA	**FAIL**	Nenhum plugin de auditoria. Sem isso nao ha trilha de quem acessou o que.
Log e auditoria	General log desligado	MEDIA	**PASS**	general_log = OFF
Log e auditoria	Slow query log ativo	BAIXA	**AVALIAR**	slow_query_log = OFF
Log e auditoria	Binary log habilitado	ALTA	**PASS**	log_bin = ON
Log e auditoria	Retencao do binary log	MEDIA	**PASS**	binlog_expire_logs_seconds = 2592000 (30 dia(s))

Log e auditoria	performance_schema habilitado	BAIXA	**PASS**	performance_schema = ON — base de qualquer diagnostico e da propria auditoria de acesso.
Dados sensiveis	Colunas candidatas a dado pessoal	MEDIA	**AVALIAR**	12 coluna(s) com nome sugestivo de dado pessoal. Classifique e decida mascaramento, cifra ou minimizacao.
Dados sensiveis	Possivel segredo em coluna de texto	ALTA	**PASS**	Nenhuma coluna de senha/token em tipo de texto simples.
Dados sensiveis	Tabelas sem chave primaria	BAIXA	**AVALIAR**	1 tabela(s) sem PK — atrapalham replicacao por linha, PITR e rastreio de alteracao.

8. Inventario do servidor

Contexto tecnico para quem le o relatorio sem ter acesso ao servidor. Util tambem como anexo de auditoria: registra a versao exata, as contas existentes e o volume de dado no momento da coleta.

Identificacao

ITEM	VALOR
Versao	`8.0.46-0ubuntu0.24.04.4`
Distribuicao	`(Ubuntu)`
Hostname	`vm`
Porta	`3306`
Datadir	`/var/lib/mysql/`
Diretorio base	`/usr/`
Charset do servidor	`utf8mb4`
Collation	`utf8mb4_0900_ai_ci`
Fuso horario	`UTC`
Uptime	`0 dia(s)`

Contas. A coluna SSL mostra se a conta exige conexao cifrada por si so; quando esta vazia, a protecao depende apenas do parametro global. A coluna de plugin identifica o metodo de autenticacao.

Contas

CONTA	PLUGIN	TRAVADA	SSL	EXPIRA	SENHA ALTERADA EM
`debian-sys-maint@localhost`	caching_sha2_password	**nao**	**nenhum**	padrao	2026-10-06 20:50:15
`lab@localhost`	caching_sha2_password	**nao**	**nenhum**	padrao	2026-10-08 02:54:06
`mysql.infoschema@localhost`	caching_sha2_password	sim	**nenhum**	padrao	2026-10-06 20:50:14
`mysql.session@localhost`	caching_sha2_password	sim	**nenhum**	padrao	2026-10-06 20:50:14
`mysql.sys@localhost`	caching_sha2_password	sim	**nenhum**	padrao	2026-10-06 20:50:14
`root@localhost`	auth_socket	**nao**	**nenhum**	padrao	2026-10-06 20:50:14
`sh@%`	caching_sha2_password	**nao**	**nenhum**	padrao	2026-10-14 02:45:13

Schemas e tamanho

SCHEMA	TABELAS	DADOS (MB)	INDICE (MB)	ENGINES
brabo	5	3.0	4.4	InnoDB
mysql	37	2.3	0.3	CSV, InnoDB
t	15	0.2	0.0	InnoDB
lab	4	0.1	0.0	InnoDB
sm	4	0.1	0.0	InnoDB
loja	1	0.0	0.0	InnoDB
sys	101	0.0	0.0	InnoDB

Maiores tabelas

TABELA	ENGINE	LINHAS (APROX.)	TOTAL (MB)	CIFRADA
`brabo.movimentos`	InnoDB	52,283	6.5	**nao**
`brabo.clientes`	InnoDB	2,000	0.4	**nao**
`brabo.auditoria_contas`	InnoDB	2,002	0.3	**nao**
`brabo.contas`	InnoDB	2,200	0.2	**nao**
`brabo.transferencias`	InnoDB	1,007	0.1	**nao**
`loja.pedidos`	InnoDB	2	0.0	**nao**
`t.audit_ped`	InnoDB	0	0.0	**nao**
`lab.movimentos`	InnoDB	10	0.0	**nao**
`lab.contas`	InnoDB	5	0.0	**nao**
`lab.clientes`	InnoDB	4	0.0	**nao**
`lab._sqlx_migrations`	InnoDB	2	0.0	**nao**
`sm.pedidos`	InnoDB	8	0.0	**nao**
`sm.func`	InnoDB	5	0.0	**nao**
`sm.clientes`	InnoDB	5	0.0	**nao**
`sm.audit_ped`	InnoDB	0	0.0	**nao**
`t.stage_clientes`	InnoDB	3	0.0	**nao**
`t.rotas`	InnoDB	4	0.0	**nao**
`t.pedidos_2026`	InnoDB	3	0.0	**nao**
`t.pedidos_2025`	InnoDB	3	0.0	**nao**
`t.pedidos`	InnoDB	7	0.0	**nao**

Parametros. Os valores abaixo sao os que estavam em vigor na coleta. Compare com o `my.cnf`: divergencia entre os dois indica parametro alterado em tempo de execucao que voltara ao antigo no proximo restart.

Parametros de seguranca

PARAMETRO	VALOR
`activate_all_roles_on_login`	`OFF`
`authentication_policy`	`*,,`
`automatic_sp_privileges`	`ON`
`binlog_encryption`	`OFF`
`connect_timeout`	`10`
`default_password_lifetime`	`0`
`general_log`	`OFF`
`innodb_redo_log_encrypt`	`OFF`
`innodb_undo_log_encrypt`	`OFF`

local_infile	OFF
log_bin	ON
max_connections	151
max_user_connections	0
partial_revokes	OFF
password_history	0
password_reuse_interval	0
require_secure_transport	OFF
secure_file_priv	/var/lib/mysql-files/
skip_name_resolve	OFF
sql_mode	ONLY_FULL_GROUP_BY,STRICT_TRANS_TABLES,NO_ZERO_IN_DATE,NO_ZERO_DATE,ERROR_FOR_DIVISION_BY_ZERO,NO_ENGINE_S
ssl_ca	ca.pem
ssl_cert	server-cert.pem
tls_version	TLSv1.2,TLSv1.3
wait_timeout	28800

9. Limitacoes e proximos passos

Esta avaliacao le configuracao. Ela nao tenta explorar nada, nao mede a forca das senhas realmente em uso (apenas se ha politica que as exija), nao verifica se o backup restaura, e nao enxerga o que acontece fora do servidor: regra de firewall, permissao de arquivo no sistema operacional, segredo em codigo da aplicacao.

O encaminhamento natural, em ordem: (1) tratar as falhas criticas e altas em janela de mudanca, comecando pelas de identidade e privilegio; (2) decidir os itens em avaliacao com quem conhece a aplicacao, registrando a decisao — aceitar risco de forma consciente e documentada e uma resposta valida; (3) repetir esta coleta apos as mudancas e comparar a nota; (4) complementar com teste de restauracao de backup e revisao das regras de rede, que estao fora do alcance desta ferramenta.

10. Referencias

Fontes usadas nas recomendacoes deste documento. Os links da coluna Doc em cada tabela apontam para a pagina especifica do parametro ou recurso tratado.

FONTE	PARA QUE SERVE
MySQL Reference Manual — Security	Capitulo de seguranca da documentacao oficial.
Security Guidelines	Recomendacoes gerais da Oracle para endurecer a instalacao.
What Is New in MySQL 8.4	Removidos e depreciados que afetam seguranca (ssl, have_ssl, default_authentication_plugin).
CIS Oracle MySQL Benchmark	Baseline de configuracao usado nas colunas de referencia.
CVE Details — MySQL	Confira CVEs da sua versao exata e planeje o patch.
ANPD — LGPD	Art. 46: medidas tecnicas de protecao do dado pessoal.

MyBraboSat 1.0.0 · by • DBA BRABO · relatorio gerado em 22/10/2026 15:58:52
Inspirado no MySAT (XeniaLAB srl, licenca MIT). Este derivado tambem e MIT.
Documento confidencial: contem o retrato da postura de seguranca do banco.